

Security Report

find-skills

MEDIUM RISK

CVSS v3.1 Base Score — Medium
4.6/10
CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:L

Skill File	SKILL2.md
Vulnerabilities	2
Evaluated by	Qwen/Qwen2.5-14B-Instruct
Date	2026-03-17 16:06:22

Executive Summary

The 'find-skills' skill helps users discover and install agent skills based on their queries. It introduces medium risk due to potential remote code execution through dynamic skill installation and data exfiltration via external HTTP requests. The overall security posture is moderately risky, requiring careful management of skill sources and secure handling of HTTP requests.

Skill Purpose

The skill is designed to assist users in finding and installing agent skills, which is inherently risky due to the potential for executing untrusted code. However, the risk can be mitigated by implementing strict validation of skill sources and securing HTTP requests.

CVSS v3.1 Base Metrics

Impact Score  3.4 / 10 Exploitability  1.2 / 10

Attack Vector	Network	Attack Complexity	High
Privileges Required	Low	User Interaction	Required
Scope	Unchanged	Confidentiality	Low
Integrity	Low	Availability	Low

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:L

Vulnerability Findings

SKV-001 Dynamic Installation of Untrusted Skills

HIGH

Category: REMOTE CODE EXECUTION / DYNAMIC CODE

Affected Content

```
npx skills add <owner/repo@skill> -g -y
```

Why It Is Dangerous

The skill allows the installation of arbitrary skills from GitHub or other sources using the 'npx skills add' command. If an attacker can influence the owner/repo@skill parameter, they could potentially install malicious code.

Attack Scenario

An attacker could craft a query that includes a malicious skill URL. For example, if the user asks to install a skill named 'malicious-skill', the agent would execute 'npx skills add malicious-skill'. If 'malicious-skill' contains harmful code, it could lead to remote code execution.

Remediation

Implement strict validation of the skill source and ensure that only trusted repositories are allowed. Additionally, avoid installing skills globally or skipping confirmation prompts.

SKV-002 External HTTP Requests for Skill Discovery

MEDIUM

Category: DATA EXFILTRATION

Affected Content

```
npx skills find [query]
```

Why It Is Dangerous

The skill uses the 'npx skills find' command to search for skills interactively or by keyword. This command makes HTTP requests to external services to fetch skill information, which could potentially include sensitive data.

Attack Scenario

An attacker could manipulate the query to include sensitive information in the HTTP request. If the skill sends this data to an external service, it could be intercepted or logged, leading to data exfiltration.

Remediation

Ensure that all HTTP requests made by the skill are secured and do not transmit sensitive data. Consider caching responses locally to reduce the number of external requests.

Dangerous Patterns Found

- npx skills add <owner/repo@skill> -g -y
- npx skills find [query]

Safe Practices Observed

- npx skills check
- npx skills update

Remediation Priority

1. First, implement strict validation of skill sources to prevent the installation of untrusted skills. Then, ensure that all HTTP requests made by the skill are secured and do not transmit sensitive data.